

Vendor Management Policy

Corporate Agentic AI Multi-Agent System Knowledge Base

Document ID:	POL-VEN-003	Version:	2.5
Effective Date:	January 15, 2026	Status:	Active / Approved
Policy Owner:	Global Procurement & Vendor Risk Directorate		

Table of Contents

1. Purpose	8. Security & Compliance Review
2. Scope	9. Contract Requirements
3. Vendor Categories	10. Vendor Risk Assessment
4. Vendor Identification	11. Vendor Performance Monitoring
5. Vendor Onboarding	12. Issue Escalation
6. Vendor Due Diligence	13. Periodic Vendor Review
7. Vendor Approval	14. Vendor Termination

1. Purpose

This policy defines the standard operating procedures for identifying, evaluating, onboarding, monitoring, and terminating third-party vendors and suppliers to mitigate operational, financial, and cybersecurity risks.

2. Scope

This policy applies to all departments and business units engaging third-party contractors, software providers, cloud services, professional consultants, and physical suppliers.

3. Vendor Categories

- Tier 1 (Strategic / Critical):** Vendors handling restricted data, core IT infrastructure, or mission-critical operational services.
- Tier 2 (Tactical / Standard):** Vendors providing specialized business support, hardware, or recurring professional services.
- Tier 3 (Commodity / Low Risk):** Office suppliers and low-impact transactional vendors.

4. Vendor Identification

Business owners must submit a formal business justification request to the Procurement Department before sourcing any new external vendor, ensuring no existing enterprise contract covers the required service.

5. Vendor Onboarding

To initiate onboarding, prospective vendors must submit mandatory documentation through the vendor portal:

- Completed W-9 / tax certification form.
- Certificate of Liability Insurance (minimum \$1,000,000 coverage).
- Company ownership profile and compliance declarations.
- Bank account verification documents for secure payment processing.

6. Vendor Due Diligence

Procurement and Legal teams conduct background checks, financial health screenings, and regulatory sanctions checks on all Tier 1 and Tier 2 vendors prior to contract drafting.

7. Vendor Approval

Vendor approvals follow a multi-stage authorization matrix based on contract financial value and risk tier:

Contract Annual Value	Required Approval Tier
Under \$25,000	Department Head / Business Owner
\$25,000 to \$100,000	Procurement Director & Financial Controller
Exceeding \$100,000	CFO and Executive Committee Approval

8. Security & Compliance Review

A formal IT security and data privacy review is **mandatory** for all vendors handling internal, confidential, or restricted corporate data. Vendors must provide valid SOC 2 Type II reports or ISO 27001 certifications.

9. Contract Requirements

All formal vendor contracts must include standard enterprise clauses covering data ownership, confidentiality (NDA), service level agreements (SLAs with 99.9% uptime targets), indemnification, and immediate breach notification provisions.

10. Vendor Risk Assessment

Vendors are assigned a risk rating (Low, Medium, High) upon onboarding and re-assessed annually. High-risk vendors undergo deep continuous monitoring regarding financial stability and security posture.

11. Vendor Performance Monitoring

Business owners must evaluate vendor performance quarterly against established key performance indicators (KPIs), including delivery timelines, service quality, and responsiveness.

12. Issue Escalation

Vendor performance failures or SLA breaches must follow a 3-tier escalation framework:

1. **Level 1:** Direct meeting between Business Owner and Vendor Account Manager (Resolution within 5 business days).
2. **Level 2:** Formal cure notice issued by Procurement Directorate (Resolution within 10 business days).
3. **Level 3:** Legal review for contract default, penalty enforcement, or termination.

13. Periodic Vendor Review

All active Tier 1 vendors undergo a comprehensive formal review **annually**. Tier 2 and Tier 3 vendors are reviewed biennially (every 2 years).

14. Vendor Termination

Upon contract expiration or termination for cause, the following protocol is strictly enforced:

- All system integrations, API tokens, and user credentials must be revoked within **24 hours**.
- Vendors must securely return or certify the cryptographic destruction of all corporate data within 30 days.
- Final invoice settlements are contingent upon successful asset and data return verification.

Disclaimer: This document is a fictional sample corporate policy created exclusively for an AI portfolio demonstration and RAG system testing project. It does not represent a real company's official policy and is not legally binding.